

Mapeo Normativo — Cada Pregunta y Sus Requisitos Regulatorios

Tabla de Correspondencia entre Preguntas CSCRМ, Indicadores IMC y Marcos Normativos

Versión 1.0 · Documento (d) del Kit de Encuesta CSCRМ

Instrucciones de Lectura

Esta tabla mapea cada pregunta de la Encuesta CSCRМ con:

- El **indicador IMC** de INCIBE-CERT correspondiente (cuando aplica)
- La **subcategoría NIST CSF 2.0** (función GV.SC u otras)
- El **control ENS RD 311/2022**
- El **artículo NIS2** o equivalente del Anteproyecto de Ley español
- El **control ISO/IEC 27001:2022** (cláusula)
- **Otras referencias** normativas relevantes (DORA, CRA, NIST SP 800-161r1, etc.)

Legenda:

-  = Requisito obligatorio / control mandatorio en la norma indicada
-  = Buena práctica recomendada / control orientativo
-  = Requisito en proceso de entrada en vigor (CRA, PQC roadmap, AIBOM)
-  = Indicador emergente sin marco normativo formal todavía

BLOQUE 0 — Perfil Organizativo

Pregunta	Propósito	Marco de Referencia
P0.1 Sector de actividad	Clasificación por tipo de entidad NIS2	 NIS2 Anexo I y II ·  Anteproyecto Ley art. 3-5
P0.2 Tamaño organizativo	Determinación de umbrales NIS2 (esencial vs. importante)	 NIS2 art. 2 ·  Anteproyecto Ley
P0.3 Rol del encuestado	Identificación del responsable CSCRМ	 ENS art. 12-13 (RSIS, RSI) ·  NIS2 art. 20
P0.5 Número de proveedores TIC	Indicador de complejidad de la cadena de suministro	 NIST SP 800-161r1 Task C-ID.SC-2
P0.6 Clasificación NIS2	Verificación de autoconciencia regulatoria	 NIS2 art. 2 ·  Anteproyecto Ley

BLOQUE I — Gobernanza y Programa CSCR

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P1.1 Política formal CSCRМ	A-PC-OGI-01	GV.SC-01	op.pl.1 (análisis riesgos)	Art. 21.1	5.19	NIST SP 800-161r1 Task C-GV.SC-1
P1.2 Integración en ERM	A-GR-OGI-03	GV.OC-05, GV.SC-03	org.1 (política de seguridad)	Art. 21.1	6.1	NIST IR 8286B-upd1 (ERM integration)
P1.3 Formación Alta Dirección	A-PC-OE1-02	GV.OC-01	mp.per.1 (formación)	Art. 20 (responsabilidad órganos dirección)	7.2-7.3	NIS2 Art. 20: formación obligatoria CISO y dirección
P1.4 Comité CSCRМ	A-GR-OGI-03	GV.SC-03	org.4 (proceso autorización)	Art. 21.1	5.1	NIST SP 800-161r1 Task C-GV.SC-3
P1.5 Presupuesto CSCRМ	—	GV.RR-02	—	Art. 21.4 (proporcionalidad)	7.1	ENISA NIS Investments 2025 (benchmark : 37% encuentra CSCRМ el área más difícil NIS2)
P1.6 Responsable formal CSCRМ / POC	—	GV.RR-01	org.2 (POC para externalizados)	Art. 20	5.3	ENS RD 311/2022: figura POC específica para servicios externalizados
P1.7 Implicación de Compras	—	GV.SC-02	op.ext.1	Art. 21.2.d	5.19-5.20	NIST SP 800-161r1 Task C-GV.SC-2
P1.8 Formación personal CSCRМ	A-PC-OE1-02	GV.OC-03	mp.per.1-2	Art. 20	7.2	—

BLOQUE II — Inventario, Clasificación y Due Diligence

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P2.1 Inventario proveedores TIC	A-GR-OE6-01	ID.AM-05, GV.SC-04 ✓	op.ext.1 (inventario de activos) ✓	Art. 21.2.d ✓	5.19-8.4 ✓	NIST SP 800-161r1 Task C-ID.SC-2
P2.2 Clasificación por criticidad	A-GR-OE5-03	GV.SC-04 ✓	op.pl.2 (análisis impacto) ✓	Art. 21.2 ✓	6.1.2 ✓	NIST SP 800-161r1 Task C-GV.SC-4
P2.3 Análisis BIA de proveedores	A-GR-OE1-03	GV.SC-05, ID.RA-01 ✓	op.cont.1 (plan de continuidad) ✓	Art. 21.2.c ✓	8.2 ✓	ISO 22301:2019 (BIA)
P2.4 MTD por proveedor crítico	A-GR-OE1-04	GV.SC-05	op.cont.1	Art. 21.2.c	8.2	ISO 22301:2019
P2.5 Análisis n-tier (subcontratistas)	—	GV.SC-04, GV.SC-06 ✓	op.ext.1 (verificación subcontratistas) ✓	Art. 21.2.d, Art. 22 ✓	8.4 ✓	NIST SP 800-161r1 Task C-ID.SC-4; Foro Nacional Ciberseguridad sep. 2025
P2.6 Evaluación pre-contrato (due diligence)	—	GV.SC-06 ✓	op.ext.1 ✓	Art. 21.2.d ✓	5.19 ✓	CCN-CERT/ISMS Forum Cuestionario Unificado feb. 2025
P2.7 Herramientas de evaluación continua	—	GV.SC-09	op.ext.1	Art. 21	5.22	ISMS Forum: pirámide 6 niveles supervisión

P2.8 Certificación n ENS/ISO 27001 exigida	—	GV.SC-05 ✓	op.ext.1 ✓	Art. 21.2 ✓	5.20 ✓	ENS RD 311/2022: certificación escalonada (Básica/Me dia/Alta)
---	---	---------------	------------	-------------	--------	---

BLOQUE III — Requisitos Contractuales

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P3.1 Cláusulas contractuales de ciberseguridad	R-CS-OE7-04	GV.SC-05 ✓	op.ext.1 ✓	Art. 21.2, 21.4 ✓	5.20-5.21 ✓	NIST SP 800-161r1 Task C-GV.SC-5
P3.2 Derecho de auditoría	—	GV.SC-05 ✓	op.ext.1 ✓	Art. 21.2.d ✓	5.22 ✓	ISMS Forum Cuestionario Unificado: nivel 6 de la pirámide
P3.3 Exigencia de SBOM	—	GV.SC-05 → SOON	— → SOON	CRA Art. 13 → SOON	8.8 → SOON	CISA SBOM Minimum Elements 2025; ENISA SBOM Landscape Analysis dic. 2025
P3.4 Plazos notificación NIS2 en contratos	T-SC-OE4-01	RS.CO-04 ✓	op.exp.7 (notificación incidentes) ✓	Art. 23 (24h/72h/1 mes) ✓	5.21 ✓	Anteproyecto Ley Ciberseguridad España
P3.5 Requisitos de subcontratistas	—	GV.SC-05 ✓	op.ext.1 (cadena subcontratación) ✓	Art. 21.2.d ✓	5.19-5.20 ✓	NIST SP 800-161r1 Task C-GV.SC-5
P3.6 Requisitos PQC en contratos	—	GV.SC-05 → SOON	— → SOON	Roadmap CE PQC 2026-2030-2035 → SOON	— → SOON	NIST FIPS 203/204/205; Comunicación CE jun. 2025

BLOQUE IV — Supervisión Continua y Monitorización

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P4.1 Monitorización continua proveedores	T-SC-OE4-01	GV.SC-09, DE.CM-09	op.mon.1 (monitorización del sistema)	Art. 21.2	5.22	NIST SP 800-161r1 Task C-DE.CM-9
P4.2 Métricas de ciberseguridad en ANS	T-SC-OE4-01	GV.SC-09	op.ext.1	Art. 21.4	5.22	ISMS Forum: pirámide supervisión; ENISA NIS Investments 2025
P4.3 Procedimiento reporte incidentes proveedor	T-SC-OE4-01	GV.SC-08, RS.CO-04	op.exp.7	Art. 23	5.21	IMC: indicador T-SC-OE4-01 (objetivo L5)
P4.4 Frecuencia revisiones formales	—	GV.SC-09	op.ext.1	Art. 21.2	5.22-9.1	ENISA Good Practices 2023
P4.5 Tiempo de respuesta proveedor ante vulnerabilidad	—	GV.SC-09	op.mon.4 (gestión vulnerabilidades)	Art. 21.2.e	8.8	ENISA NIS Investments 2025: 28% tarda >3 meses
P4.6 Monitorización sw/hw no autorizado	T-SC-OE1-02	DE.CM-01	op.mon.1	Art. 21.2	8.7-8.8	IMC: T-SC-OE1-02
P4.7 Tiempo detección incidente en CS	—	DE.AE-04	op.exp.1	Art. 23	9.1	Cipher/ Prosegur 2026: benchmark 254 días promedio

BLOQUE V — Respuesta a Incidentes con Terceros

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P5.1 PRI con módulo CSCRM	R-GI-OE3-01	GV.SC-08, RS.RP-01 ✓	op.exp.7 ✓	Art. 21.2.a, 23 ✓	5.26-5.28 ✓	NIST SP 800-161r1 Task C-RS.RP-1
P5.2 Proveedores en ejercicios de simulación	R-GI-OE1-01	GV.SC-08 📋	op.exp.7 📋	Art. 21.2.a 📋	5.26 📋	ENISA Good Practices 2023
P5.3 Cumplimiento plazos notificación	—	RS.CO-04 ✓	op.exp.7 (plazos de notificación) ✓	Art. 23 (24h/72h/1 mes) ✓	5.28 ✓	Anteproyecto Ley: hasta 10M€ multa por incumplimiento
P5.4 Proveedores alternativos identificados	R-CS-OE5-02	GV.SC-07, RC.RP-01 ✓	op.cont.2 (alternativas) 📋	Art. 21.2.c 📋	8.2 📋	IMC: R-CS-OE5-02

BLOQUE VI — Continuidad de Negocio y Resiliencia

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P6.1 BCP con escenarios de proveedor	R-CS-OE1-01	GV.SC-08, RC.RP-01 ✓	op.cont.1-2 ✓	Art. 21.2.c ✓	8.2 ✓	ISO 22301:2019; IMC R-CS-OE1-01
P6.2 Pruebas formales BCP (escenarios proveedor)	R-CS-OE3-01	GV.SC-08, RC.RP-01 ✓	op.cont.2 (pruebas) ✓	Art. 21.2.a ✓	8.2 ✓	IMC R-CS-OE3-01; ISO 22301
P6.3 Medición RTO real vs. objetivo	R-CS-OE1-06	RC.RP-02	op.cont.1	Art. 21.2.c	9.1	IMC: R-CS-OE1-06, R-CS-OE3-03, R-CS-OE4-04

BLOQUE VII — SBOM, PQC e IA

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P7.1 Exigencia de SBOM a proveedores	—	GV.SC-05 	—	CRA Art. 13 	8.8 	CISA SBOM Minimum Elements 2025; ENISA SBOM Analysis dic. 2025
P7.2 Uso activo del SBOM en gestión vulnerabilidades	—	DE.CM-09, ID.RA-01 	op.mon.4 	CRA Art. 13 	8.8 	ENISA SBOM Landscape Analysis 2025
P7.3 Inventario criptográfico (crypto BOM)	—	PR.DS-02 	— 	Roadmap CE PQC 	8.24 	NIST FIPS 203/204/205; apexanalytix 2026
P7.4 Hoja de ruta PQC	—	GV.SC-05 	— 	Roadmap CE PQC 2026-2030-2035 	8.24 	Comunicación CE jun. 2025; NIST FIPS 203/204/205; Talan/RiskInsight 2026
P7.5 Identificación de proveedores con IA/ML	—	GV.SC-04 	—	—	—	ACSC AI/ML Supply Chain Guidance oct. 2025; ISO 42001
P7.6 Exigencia de AIBOM	—	GV.SC-05 	—	—	—	ACSC oct. 2025; ISO 42001 
P7.7 Verificación integridad artefactos sw/IA	—	PR.DS-02 	op.sw.1 (gestión de configuración) 	Art. 21.2 	8.20 	ACSC oct. 2025; SLSA framework

P7.8 Gestión drift modelos IA	—	DE.CM-09 ⚡	—	Reglamento IA EU 2024/1689 ⚡	—	ACSC oct. 2025; Hodeitek CISO Playbook 2025 ⚡
--	---	---------------	---	---------------------------------------	---	--

BLOQUE VIII — Zero Trust y Acceso de Proveedores

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P8.1 Implementación Zero Trust para proveedores	—	PR.AA-05, PR.IR-01	op.acc.1 (control de acceso)	Art. 21.2.i 	8.2-8.3	NIST SP 800-207 (Zero Trust Architecture); ENS
P8.2 Principio de mínimo privilegio	—	PR.AA-05 	op.acc.4 (derechos de acceso) 	Art. 21.2.i 	8.2	NIST SP 800-207; CIS Controls v8
P8.3 Logging y auditoría actividad proveedores	—	DE.CM-03, DE.AE-02 	op.mon.1-2 	Art. 21.2.j 	8.15-8.17	NIST SP 800-92 (log management)
P8.4 Revisión y revocación de accesos	—	PR.AA-02 	op.acc.1 (ciclo de vida accesos)	Art. 21.2.i 	8.2	CIS Controls v8 Control 5
P8.5 Solución PAM para accesos privilegiados	—	PR.AA-05	op.acc.5 (autenticación privilegiada) 	Art. 21.2.i 	8.2	CIS Controls v8 Control 5.4

BLOQUE IX — Intercambio de Información

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P9.1 Participación en ISACs / grupos sectoriales	A-PC-OE5-01	GV.SC-10, GV.OC-05	—	Art. 29 (intercambio voluntario)	5.5-5.6	IMC A-PC-OE5-01 (objetivo L5)
P9.2 Acuerdos formales de cooperación	A-PC-OE5-01	GV.OC-05	—	Art. 29	5.5	IMC A-PC-OE5-01
P9.3 Uso sistemático de alertas CCN/INCIBE /ENISA	—	ID.RA-02	op.mon.4	Art. 29	8.7	CCN-CERT Avisos; INCIBE Alertas Tempranas
P9.4 Participación en evaluaciones coordinadas	—	GV.SC-09	—	Art. 22 (evaluaciones coordinadas NIS2)	—	NIS2 Art. 22: evaluaciones sectoriales coordinadas UE

BLOQUE X — Cumplimiento y Ciclo de Vida

Pregunta	Indicador IMC	NIST CSF 2.0	ENS RD 311/2022	NIS2 / Anteproyecto	ISO 27001:2022	Otras Referencias
P10.1 Gap analysis normativo CSCRm	—	GV.SC-03 ✓	op.pl.1 ✓	Art. 21.1 ✓	9.2 ✓	ENS; NIS2; DORA (sector financiero)
P10.2 Gestión ciclo de vida del proveedor	R-CS-OE8-01	GV.SC-10 ✓	op.ext.1 ✓	Art. 21.2.d ✓	5.19-5.23 ✓	NIST SP 800-161r1 Task C-GV.SC-10
P10.3 Incidentes originados en CS (últimos 24 meses)	—	DE.AE-04, RS.MA-01 ✓	op.exp.1-7 ✓	Art. 23 ✓	5.26 ✓	Cipher / Prosegur 2026; INCIBE Balance 2025
P10.4 Impacto de incidentes en CS	—	RS.MA-02 📋	op.exp.7 📋	Art. 23 ✓	5.27 📋	ENISA NIS Investments 2025
P10.5 Marcos más influyentes	—	—	—	—	—	Contextual: identificación de marcos de referencia usados

BLOQUE XI — Madurez Global y Prioridades

Pregunta	Indicador IMC	Relevancia	Referencias
P11.1 Autoevaluación madurez global	—	Indicador de metacognición; contraste con IGM calculado	CMMI; INCIBE IMC escala L0-L5
P11.2 Presupuesto CSCRМ (% ciberseguridad)	—	Indicador de compromiso organizativo	ENISA NIS Investments 2025: 37% CSCRМ área más difícil
P11.3 Principales obstáculos	—	Diagnóstico de barreras estructurales	Foro Nacional Ciberseguridad sep. 2025
P11.4 Prioridades próximos 12 meses	—	Planificación prospectiva	NIST SP 800-161r1; ENS; CCN-CERT/ISMS Forum
P11.5 Disposición participación piloto sectorial	—	Indicador de disposición a la colaboración público-privada	Foro Nacional Ciberseguridad; NIS2 Art. 29
P11.6 Campo abierto	—	Captura de información cualitativa no estructurada	—

Resumen de Cobertura Normativa

Marco Normativo	N.º Preguntas Mapeadas	Cobertura
ENS RD 311/2022	38	Alta
NIS2 / Anteproyecto Ley Coordinación y Gobernanza	42	Alta
NIST SP 800-161r1 (C-SCRM)	28	Media-Alta
NIST CSF 2.0 (GV.SC + otras)	45	Alta
ISO/IEC 27001:2022 (cláusulas 5.19-5.23 + otras)	36	Alta
INCIBE-CERT IMC v2.8	22	Media
Cyber Resilience Act (CRA)	4	Emergente
Roadmap PQC (CE + NIST FIPS 203/204/205)	3	Emergente
DORA (sector financiero)	2	Sectorial
ISO 42001 / Reglamento IA	2	Emergente
ACSC AI/ML Supply Chain Guidance	3	Referencia

© 2026 · *Mapeo Normativo CSCRМ España · Documento (d) del Kit de Encuesta*

Elaborado a partir de: ENS RD 311/2022 · NIST CSF 2.0 · NIST SP 800-161r1 · ISO/IEC 27001:2022 · INCIBE-CERT IMC v2.8 · NIS2 (UE 2022/2555) · Anteproyecto Ley Coordinación y Gobernanza Ciberseguridad España (ene. 2025) · CRA · CISA SBOM 2025 · ACSC AI/ML Guidance oct. 2025